STRIDE Threat Analysis & Mitigation — User Profile Data Management

Principal Security Analyst: Alister A. Rodrigues, Security Analyst, Obsidian SecureTech Solutions

Analytical Framework: *Threat Modeling for E-Commerce Customer Data Processes*

Date: November 2024

Executive Summary

This paper presents a detailed threat model for the process of storing and managing user profile data, containing sensitive personally identifiable information (PII), that would be frequently accessed across multiple interactions. This constant access raises the potential for exposure to security threats, thus making strong security measures essential.

Using the STRIDE methodology, key threats to this process are identified, including spoofing, tampering, denial of service, elevation of privilege, repudiation and Information disclosure. Each threat is then analyzed within its trust boundary, covering the interactions between users, profile management system, database and third party integrations. Identifying the vulnerabilities and recognizing the risk involved, targeted mitigation strategies are proposed to enhance the security of user data, including but not limited to Multi Factor Authentication (MFA), Transport Layer Security (TLS), Role Based Access Controls (RBAC) and audit logging.

In addition to minimizing the risk of security breaches, implementing these mitigation methods aligns with the data protection regulations, including but not limited to GDPR, CCPA, PCI DSS.

Storing & Managing User Profile Data

User profile data includes sensitive personally identifiable information (PII) such as names, addresses, payment methods and preferences, making it a lucrative target for attackers. As this data is accessed frequently not only during registration and login but also whenever users update their information or during payments and order purchases, increasing its exposure to potential threats.

It is a critical business process that directly impacts the organization's relationship with the customers, ensuring the security of this data shall enable trust building with the customers, demonstrating the organizations commitment towards safeguarding personal information. Any compromise in the protection of user data could lead to reputational damage, erosion of customer confidence and loyalty, negatively affecting business growth, customer retention and brand integrity.

Additionally storing and managing of all the user's personally identifiable information falls under strict data protection regulations like GDPR (GDPR, 2016), CCPA (State of California Department of Justice, 2024) and PCI DSS (*Document Library*, 2024). Adhering to these standards would not only reduce legal and compliance risks but also help establish the organization as a trustworthy and responsible company in the eyes of the customers.

Figure 1

DFD for Storing & Managing User Profile Data Process

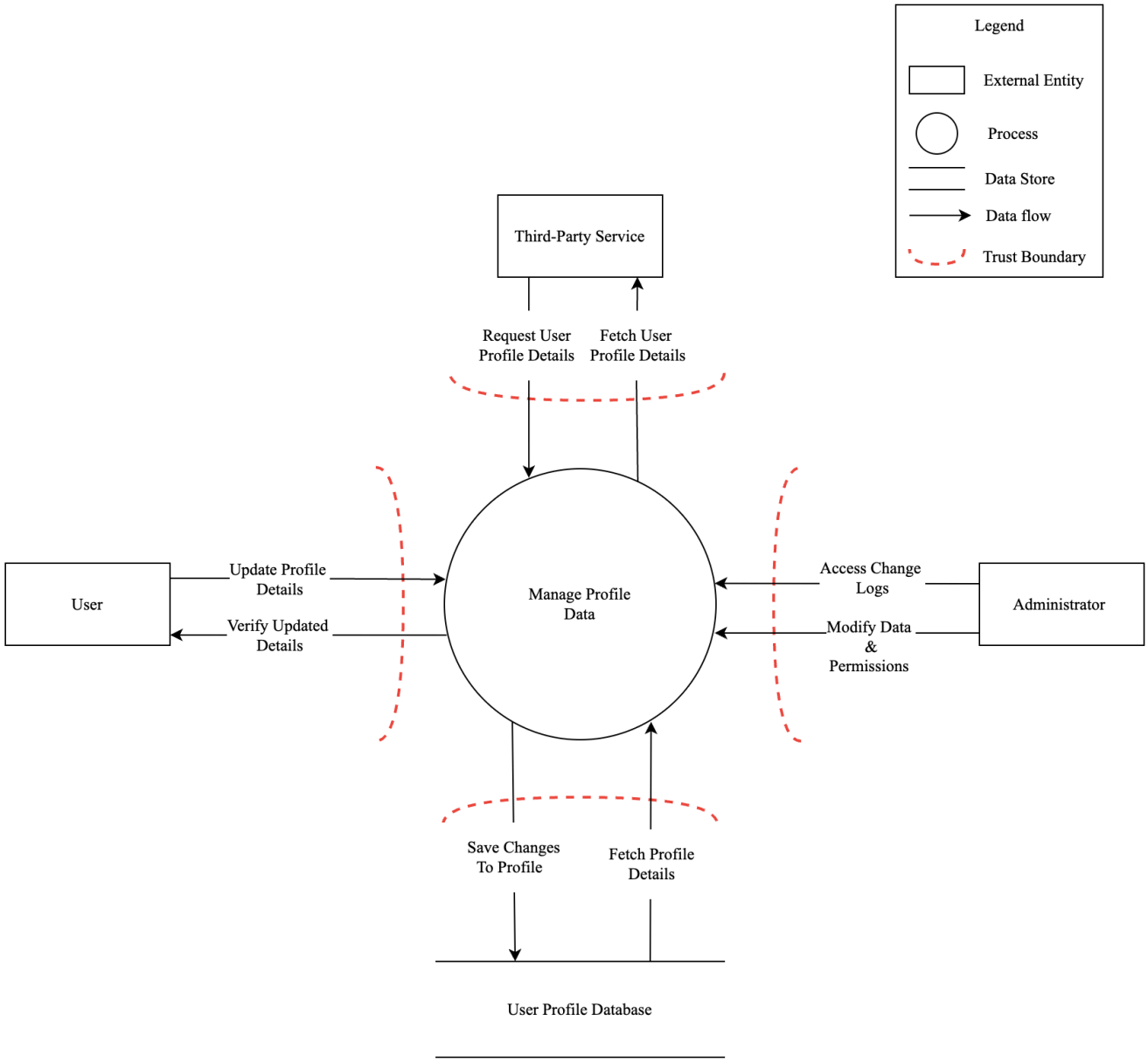

Table 1

STRIDE Analysis for Storing & Managing User Profile Data Process

Trust Boundary	STRIDE Category	Threat Identified	Vulnerability Identified	Control Methods
User ↔ Manage Profile Data	Spoofing	Attackers impersonate legitimate users	Weak authentication mechanisms	Implement Multi Factor Authentication and enforce strong password policies with complexity requirements
	Tampering	Data modification during transmission	Lack of transport security	Implement TLSv1.3, request signing and integrity verification
	Repudiation	Users deny change actions to account or data	Lack of logging for user actions	Enable cryptographically signed audit trails, secure timestamping, and enable user notifications for critical changes.
	Information Disclosure	Unauthorized data access through network interception	Unencrypted data transmission	Implement End-to-End Encryption, secure session management with auto expiry session-specific encryption keys
	Denial of Service	API flooding and automated attacks	No request rate controls	Enable rate limiting per IP/User, traffic analysis and automatic IP blocking
Manage Profile Data ↔ Database	Tampering	Unauthorized database modifications	Vulnerability to SQL injection and weak access controls	Use prepared statements with strong typing, enable strong input validation policies
	Information Disclosure	Data exposure through database queries	Excessive database permissions	Implement least privilege access, column level encryption and dynamic data masking
	Denial of Service	Database resource exhaustion	Unrestricted query complexity and heavy load requests	Implement Query timeout limits, connection pooling and query optimization.

Table 1 Continued

Trust Boundary	STRIDE Category	Threat Identified	Vulnerability Identified	Control Methods
	Elevation of Privilege	Unauthorized privilege escalation	Insufficient access controls	Implement Role-based access controls with regular rotation and Privileged Access Management with regular permission audits
Admin ↔ Manage Profile Data	Spoofing	Unauthorized access by impersonating an admin	Insufficient admin authentication	Implement hardware security keys for admin access, time based access windows and IP allowlisting
	Tampering	Unauthorized admin data changes	Lack of change tracking	Implement change and control management and logging, version control for configurations and four-eyes principle for critical changes
	Repudiation	Admins deny unauthorized changes	No detailed record of administrative actions	Enable Mutual Authentication, generate and log change tickets for admin actions, restrict access tokens
Manage Profile Data ↔ Third-Party Services	Information Disclosure	Unauthorized data exposure to third-party services	Insufficient API security	Implement API authentication, data minimization, enforce data classification controls
	Tampering	Data manipulation by third-party service	Inadequate API security and lack of control over third-party access	Implement mutual authentication over TLS, API whitelisting, API key rotation
	Denial of Service	Third-party API abuse	Unrestricted API usage	Enable API rate limiting per Client/IP, Circuit breakers with automatic recovery

Conclusion

From the STRIDE threat model, it can be observed that the process of managing user profile data includes critical risks like spoofing, elevation of privilege, data tampering, information disclosure and denial of service attacks. These risks stem from both internal vulnerabilities like weak authentication and insufficient access controls to external threats like network interception and automated attacks, if left unaddressed, these risks could compromise sensitive user data thereby damaging the organization's reputation and resulting in legal consequences and fees under data protection regulations.

To strengthen the security in this process, defense-in-depth strategies can be implemented that addresses each risk at the required layers, from secure data transmission protocols to strong authentication policies and audit logging, such a layered approach shall ensure reduced likelihood of security incidents along with protecting business assets and building customer trust towards the business.

Risks & Recommended Mitigation Strategies

To address the security risks against spoofing, Multi Factor Authentication (MFA) should be implemented for all user and administrative accounts, the technological solutions recommended for MFA are Microsoft Authenticator or Google Authenticator for static time-based one-time passwords (TOTP) and Duo Security is recommended if the organization requires adaptive MFA features to further secure against impersonation attempts based on factors like user behavior, location, and device risk (*Multi-Factor Authentication*, n.d.).

Data integrity during transmission should be ensured by implementing Transport Layer Security (TLS) with the latest version v1.3, alongside with request signing for additional verification, the recommended technologies and services are DigiCert, a Certificate Authority for paid certificate service, and Let’s Encrypt for a free and open source option, and for request

signing it is recommended to use TLS Mutual Authentication (mTLS) feature provided by DigiCert (*Istio*, 2024), or using HMAC if using Let's Encrypt as a Certificate Authority.

To address risks regarding repudiation, cryptographically signed audit logs and secure timestamping should be enabled, the recommended technology and services are Splunk as a paid solution and Graylog (*Graylog Documentation*, 2024) as an open source cost effective alternative for traditional logging solutions, providing real time log analysis, monitoring, visualization and centralized log management.

For risks against information disclosure implement TLSv1.3 which provides the feature of end-to-end encryption to secure data in transit and AES-256 encryption using reliable libraries (e.g. Crypto++, OpenSSL) for data at rest (Kekayan, 2018), and for data in use implement data obfuscation and tokenization techniques to minimize data exposure during processing. Additionally enabling secure session management is advised, the recommended solution for this would be JWT-based token authentication as it provides stateless , scalable and tamper proof approach for user authentication, as they are self contained JSON tokens signed with algorithms like HS256 or RS256, ensuring both integrity and authenticity (auth0.com, n.d.).

To mitigate Denial of Service (DoS) risks such as API flooding, implement rate limiting and automated IP blocking to prevent API abuse. The recommended solutions are Cloudflare Rate Limiting (*Cloudflare Advanced Rate Limiting*, 2020), AWS WAF, and intrusion detection systems like Snort and Suricata for monitoring and filtering traffic. With additional configuration, Suricata can also act as a network intrusion prevention system providing both detection and blocking capabilities (*Suricata User Guide — Suricata 6.0.0 Documentation*, n.d.).

To prevent unauthorized access to databases, Role-Based Access Control which enforces the principle of least privilege, ensuring employees have access only to what is necessary for their roles, while users are granted access based on their specific needs. Additionally implement

Privileged Access Management (PAM) solutions, the recommended services for this would be BeyondTrust or CyberArk, that provide secure management and auditing of elevated privileges, assisting to prevent unauthorized actions and ensuring accountability in systems with high-level access (*Privileged Access Management and Remote Access Software*, n.d.).

To secure against unauthorized access to the API and to reduce the data exposure from third-party API integrations, implement OAuth 2.0 with short token lifespan to provide secure authentication and enforce data minimization practices to ensure that third-party access is limited to only the essential data required for the integration, the recommended services would be Auth0, Okta, and AWS API Gateway allowing fine-grained control over user data and access permissions (*Building Fine-Grained Authorization Using Amazon Cognito, API Gateway, and IAM*, 2021).

To prevent SQL injection attacks, enforce the use of prepared statements and parameterized queries to ensure proper handling of user inputs, additionally deploy Web Application Firewalls (WAF) like AWS WAF (*AWS WAF, AWS Firewall Manager, and AWS Shield Advanced*, n.d.) and Cloudflare WAF and integrate these services with OWASP ModSecurity Core Rule Set as an added layer of protection for the database against SQL injection attacks, ensuring prevention against malicious queries (OWASP, n.d.).

References

auth0.com. (n.d.). *JWT.IO*. Jwt.io. https://jwt.io

AWS WAF - AWS WAF, AWS Firewall Manager, and AWS Shield Advanced. (n.d.). Docs.aws.amazon.com. https://docs.aws.amazon.com/waf/latest/developerguide/waf-chapter.html

Building fine-grained authorization using Amazon Cognito, API Gateway, and IAM. (2021, May 21). Amazon Web Services. https://aws.amazon.com/blogs/security/building-fine-grained-authorization-using-amazon-cognito-api-gateway-and-iam/

Cloudflare advanced rate limiting. (2020, January 1). Cloudflare. https://www.cloudflare.com/static/f2297b58bc4adc5d28dc3cfa0e081d54/Cloudflare_Advanced_Rate_Limiting_Datasheet.pdf

Document Library. (2024, September 24). PCI Security Standards Council. https://www.pcisecuritystandards.org/document_library/?hsCtaTracking=885a24d0-8ede-4574-a27b-0a860f17a33a%7Cc910d9ec-4c58-45d2-890a-81c1c8ccbf6f

GDPR. (2016). *General Data Protection Regulation (GDPR)* . General Data Protection Regulation (GDPR). https://gdpr-info.eu

Graylog Documentation. (2024). Graylog.org. https://go2docs.graylog.org/current/home.htm

Istio. (2024). Digicert.com. https://docs.digicert.com/nl/trust-lifecycle-manager/connectors/infrastructure-automation/istio.html

Kekayan. (2018, July 7). *Encrypt files using AES with OPENSSL*. Medium. https://kekayan.medium.com/encrypt-files-using-aes-with-openssl-dabb86d5b748

Multi-Factor Authentication (MFA). (n.d.). Duo Security. https://duo.com/product/multi-factor-authentication-mfa

OWASP. (n.d.). *OWASP ModSecurity Core Rule Set*. Owasp.org. https://owasp.org/www-project-modsecurity-core-rule-set/

Privileged Access Management and Remote Access Software. (n.d.). Www.beyondtrust.com. https://www.beyondtrust.com

State of California Department of Justice. (2024, March 13). *California Consumer Privacy Act (CCPA)*. State of California - Department of Justice - Office of the Attorney General. https://oag.ca.gov/privacy/ccpa

Suricata User Guide — Suricata 6.0.0 documentation. (n.d.). Docs.suricata.io. https://docs.suricata.io/en/suricata-6.0.0/